

What Is Azure Web Application Firewall (WAF)?

A web application firewall (WAF) offers centralized protection of web applications against common vulnerabilities and exploits. Azure WAF is a cloud native service that helps protect web apps against common web threats and security vulnerabilities like cross-site scripting (XSS) and SQL injection (SQLi).

You can deploy Azure WAF in minutes to block malicious attacks and get visibility into your environment. Azure WAF offers several deployment options using Azure Application Gateway, Azure Content Delivery Network (CDN), or Azure Front Door.

This is part of a series of articles about [cloud security](#).

7 Key Features of Azure WAF

Azure Web Application Firewall offers the following main features:

1. **Managed rules** - Microsoft maintains WAF rules to detect and block common threats, automatically updating the firewall when changing a rule.
2. **Custom rules** - supplement managed rules to extend coverage to more web application threats.
3. **WAF policies** - combine managed and custom rules with other firewall settings to create complete policies to protect different web applications.
4. **Modes** - Azure WAF operates in detection mode (only logging violations) or prevention mode (logging and blocking unauthorized requests).
5. **Exclusions** - Azure WAF can ignore certain attributes when validating requests.
6. **Request limits** - Azure WAF can flag requests exceeding a specified size limit.
7. **Alerts** - integrate with Azure Monitor to generate alerts immediately when the WAF detects threats.

Azure WAF Use Cases

Here are common Azure WAF use cases:

Web Apps with Sensitive or Proprietary Data

Most malicious actors have a specific objective when launching an attack. Perhaps the most common objective is gaining access to sensitive personal information like IDs and driver's license numbers, financial information like customer credit card numbers, proprietary information, and trade secrets.

Actors can use this information directly, for example, by purchasing goods with stolen credit card numbers. However, the actors are more likely to hold data for ransom or sell it in a criminal marketplace. Organizations running web apps that store proprietary or sensitive data can leverage Azure WAF to protect it against intrusion and exfiltration.

Web Apps that Require Authentication

Many actors try to obtain account credentials, usually usernames and passwords, for various malicious purposes. For example, actors can use compromised credentials to access a web app while impersonating an authorized user, run commands or scripts with stolen elevated privileges, access other network parts, or sign in to other services and sites.

Organizations using web apps that require users to sign in with credentials can employ Azure WAF to detect exploits like local file inclusion and SQL injections attempting to steal or display account credentials.

Web Apps with Security Requirements and Budget Constraints

Web development teams often try to implement security measures against the top 10 web security vulnerabilities mentioned by the OWASP organization. However, creating and maintaining secure code can be a time-consuming, laborious endeavor.

Protecting a web app against all vulnerabilities may take thousands of hours. Azure WAF can help speed up this process, letting you configure an Azure Application Gateway instance or Azure Front Door profile in minutes.

How Azure Web Application Firewall Works

In addition to the core features of Azure WAF, it's important to understand how the firewall works. These features help protect web applications from common threats by enabling the following processes.

Input Sanitization

Various sophisticated exploits threaten web applications, but most threats arise from implicitly trusting user input. One common attack technique is SQL injection.

For instance, many web forms allow users to sign in with username and password textboxes and sign-in buttons. The application stores the credentials as variables, executing a command such as:

```
sql = "SELECT * FROM users WHERE username='"Visitor1' AND  
password='"QWERTY123'"
```

Executing this statement signs in the user if the query returns a record.

However, attackers could enter 'Admin'-- as the username field, leaving the password field empty. The double dash often causes the SQL system to ignore everything that follows. If there is a user called Admin, the attacker can sign in as an administrator.

Azure WAF eliminates this trust, insulating the application from user-supplied input. It sanitizes all input to preempt malicious scripts. Sanitizing involves different processes for different contexts. One example is removing elements like SQL command indicators, preventing the input from harming the system.

Rules, Groups, and Core Rule Sets

Azure WAF applies firewall rules to filter incoming HTTP requests. Rules are code that recognizes and blocks specific threats. You will mostly use managed rules handled by Microsoft's security team. You can implement multiple related rules using a core rule set that combines rules based on OWASP's common vulnerabilities.

Azure WAF currently offers three core rule sets targeting specific exploits (CRS 2.29, CRS 3.0, and CRS 3.1). Azure's managed rules don't always cover all threats to a web application,

but you can create custom rules that allow or block actions based on request methods and variables.

Detection and Prevention Modes

You can choose a mode depending on how you want Azure WAF to handle incoming requests:

- **Detection mode** - logs suspicious requests but allows them.
- **Prevention mode** - logs requests and blocks them.

For example, you might use detection mode to test an application and identify issues like false positives and false negatives. You can switch to prevention mode when deploying the app.

Deployment Options

Azure WAF operates as part of your front end Azure solution. Start by creating firewall policies that include settings such as:

- The managed rules to enable.
- The rules within a CRS to disable.
- Additional custom rules.
- The mode.

The following Azure services support WAF deployment:

- **Front Door** - associate the policy with your Azure Front Door profile.
- **Application Gateway** - configure or create an application gateway for Azure WAF, choosing the WAF tier. Associate the WAF policy with the gateway.
- **Azure Content Delivery Network (CDN)** - centrally protect web applications and their content.

Cloud Security with HackerOne

Migrating code, apps, and assets to the cloud environment create new risks. HackerOne's consolidated platform addresses the cloud security risks by calling on a strong community of ethical hackers that bring unique expertise to find vulnerabilities scanners and AI miss.

With the built-in visibility and reporting HackerOne provides, organizations can protect their cloud environment against multiple threat vectors, including cloud misconfigurations, data exposures, subdomain takeovers, unauthorized access to applications, and many more.

There are three main HackerOne product offerings that can assist organizations looking to harden their cloud attack surface:

- 1. [HackerOne Assessments](#) brings a creative, community-led approach to cloud pentesting that gives organizations more coverage, real-time results, and seamless remediation workflows to find and fix vulnerabilities fast. HackerOne's [AWS-specific solutions](#) allow organizations to gain visibility into cloud-specific threats across cloud applications, APIs, IAM risks, serverless deployments, DNS management, and S3 issues by working with background-checked, AWS-certified hackers. The vulnerability results and intelligence can also be seamlessly routed [from HackerOne to AWS Security Hub](#) for fast, effective security actions.
- 2. [HackerOne Bounty](#) minimizes the risk of cyberattacks by inviting ethical hackers to help organizations find and mitigate cloud security gaps.

[HackerOne Response](#) helps organizations implement a vulnerability disclosure policy to comply with regulations while arming security teams with vulnerability intelligence across a myriad of cloud-based assets.

Company

Knowledge

Resources

Leadership

Center

Blog

Careers

Application Security

Documentation

Partners

Penetration Testing

Leaderboard

Newsroom

Cloud Security

Partner Portal

Contact Us

Hacking

Resources

Cybersecurity

Attacks

DevSecOps

Contacted
by a  hacker?

Trust